



Cybersecurity Intern – Learning Tasks & Deliverables

PREPARED BY: SHAMKUMAR
ROLE: CYBERSECURITY INTERN

Agenda

- ▶ Task 1 – Asset Inventory Review
- ▶ Task 2 – Vulnerability Management
- ▶ Task 3 – Endpoint Security Compliance
- ▶ Task 4 – Phishing Email Analysis
- ▶ Task 5 – Security Awareness Assessment
- ▶ Task 6 – Cybersecurity & Compliance Frameworks

Task 1 – Asset Inventory Review

- ▶ Total Endpoints: 3031
- ▶ Duplicate Hostnames: 169

Asset Breakdown

Category	Count
Windows Laptops	2450
Windows Servers	174
Linux Servers	215
Windows Desktops	47
macOS Laptops	86
macOS Desktops	7
Azure Virtual Machines	49
AWS EC2 Instances	3
Total	3031

Root Cause Analysis

A sample of duplicate hostnames was investigated to determine the root cause.

- ▶ VM-SERVER-01 – False duplicate. Same asset ID and IP. Caused by a single machine with multiple network interfaces. No security risk or license waste.
- ▶ JUMP-SERVER-01 – True duplicate. 3 offline entries, 1 online. Caused by multiple re-imaging without removing the old SentinelOne agent.

Risks from true duplicates:

- ▶ Inflated asset counts and wasted licenses.
- ▶ Incident response confusion — analysts may investigate the wrong entry.
- ▶ **Recommendation:**
Flag offline duplicates for removal. Implement process to uninstall S1 agent before re-imaging.

TASK 2: VULNERABILITY MANAGEMENT EXERCISE

Metric	Value
Total Endpoints Scanned	3031
Critical Vulnerabilities	0
High Severity	0
Medium Severity	0
Low Severity	0

Finding:

No vulnerabilities were identified in SentinelOne across all 3,031 endpoints.

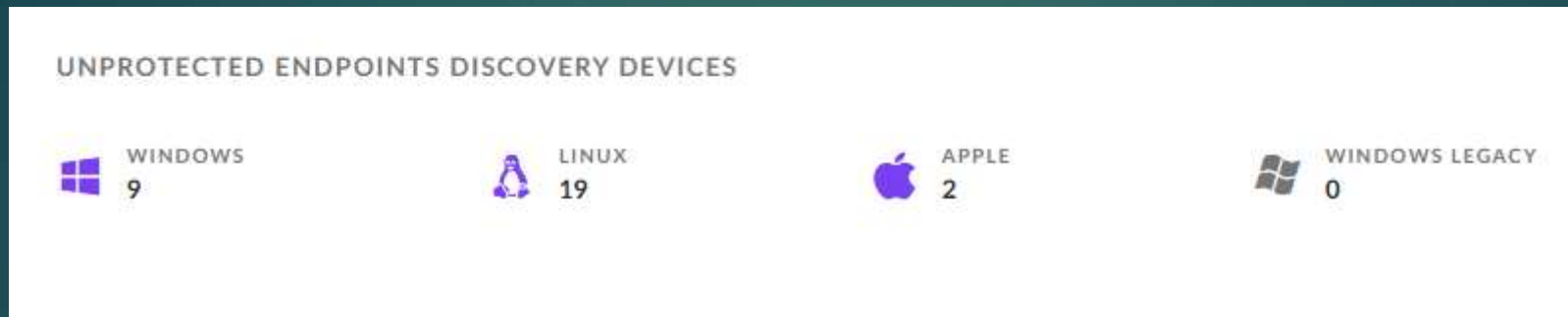
Interpretation:

No OS-level vulnerabilities detected by SentinelOne. Third-party apps not fully covered — dedicated scanner recommended for complete visibility.

Recommendation:

Continue patching. Supplement S1 with dedicated vuln scanner. Monitor weekly.

TASK 3: ENDPOINT SECURITY REVIEW



Metric	Value
Total Endpoints (with SentinelOne)	3031
Unprotected Endpoints Discovered	30
USB Restrictions	Enabled

Key Takeaways:

- ▶ ✓ 100% EDR coverage on managed endpoints
- ▶ ⚠ 30 unprotected devices found on the network

Task 3: How Unprotected Endpoints Were Identified

- ▶ Protected endpoints act as **network scanners**
- ▶ Scan local subnets for devices without S1 agent
- ▶ Requires **2 protected endpoints** per subnet to scan

Risk:

- ▶ 30 blind spots = no detection, no response

Task 3: Recommendations & EDR Logic

Action	Timeline
Install S1 agent on all 30 unprotected devices	6 days
Prioritize Windows (9) first	3 days
Weekly monitoring for unprotected devices	Ongoing

EDR Detection Logic (SentinelOne)

- ▶ **Static** – Matches known malware hashes
- ▶ **Behavioral** – Flags suspicious process actions (e.g., PowerShell spawning cmd)
- ▶ **Cloud Sandbox** – Tests unknown files safely
- ▶ **Storylines** – Connects events into full attack chain

TASK 4 – PHISHING & EMAIL SECURITY ANALYSIS

From: it-security@silverlakeaxis-support.com
Reply-To: verification@silverlakeaxis-secure.com
To: employee@silverlakeaxis.com
Subject: ⚠ URGENT: Security Update Required – Ransomware Incident Follow-Up

Dear Colleague,

As you may be aware, Silverlake Axis Ltd experienced a ransomware incident in October 2025 involving unauthorized access to certain systems . As part of our ongoing security review, we are requiring all employees to re-verify their Microsoft 365 credentials.

Please click the link below to confirm your identity and ensure your account remains active:

 <https://silverlakeaxis-secure-portal.com/verify>

Failure to complete this verification within 24 hours will result in restricted access to internal systems.

For any questions, contact IT Support.

Thank you,

IT Security Team

Silverlake Axis Ltd

Task 4: Phishing Analysis – Authentication & Sender Details

Check	Finding	Verdict
Sender Address	it-security@silverlakeaxis-support.com	✗ Not official domain
Reply-To	verification@silverlakeaxis-secure.com	✗ Different domain — suspicious
SPF, DKIM, DMARC	Would likely fail — domain not authorized, no signature, no policy	✗ Authentication would fail

Note: This email originates from an external domain impersonating Silverlake Axis. For external emails, SPF/DKIM/DMARC failures are a critical red flag

SPF: Sender Policy Framework

DKIM: DomainKeys Identified Mail

DMARC: Domain-based Message Authentication, Reporting and Conformance

Task 4: Phishing Analysis – Indicators & Verdict

Check	Finding	Verdict
URL	silverlakeaxis-secure-portal.com	✗ Fake domain
Social Engineering	Urgency ("24hrs"), fear (ransomware), authority (IT Security)	✗ Classic phishing
Headers	From/Reply-To mismatch, fake domain	✗ Red flags

Verdict

✓ **Confirmed Phishing** — Domain impersonation, authentication would fail, urgency tactics used.

Task 5: Security awareness gap assessment

#	Gap	Why It's a Gap	Recommendation
1	Employees fall for phishing attacks	Staff struggle to identify urgency based phishing	Monthly phishing simulations
2	Unauthorized AI / third-party tool usage	Employees paste internal source code, banking logic, or sensitive data into unapproved AI tools — risking data leakage	AI usage policy + approved tool list + awareness training
3	Failure to report suspicious activity	Employees don't report phishing or unusual behaviour (fear or uncertainty)	Simplify reporting process + encourage "see something, say something" culture



TASK 6: CYBERSECURITY & COMPLIANCE FRAMEWORKS

SOC 1 – Financial Reporting Controls

- ▶ **What it covers:** Controls that affect how our clients report their finances — payroll, billing, claims.
- ▶ **Why it matters:** If our system makes a financial error, our client's financial statements are wrong.
- ▶ **When it's used:** By companies that process financial transactions for clients.
- ▶ **Type 1 vs Type 2:** Type 1 checks design only. Type 2 checks design + whether it actually works over time (6–12 months).

SOC 2 — Security & Trust Services

- ▶ **What it covers:** Customer data security — how we protect data, keep systems available, and handle privacy.
- ▶ **Why it matters:** Clients want proof their data is safe with us.
- ▶ **When it's used:** By SaaS, cloud, and tech companies handling customer data.
- ▶ **Key:** Security is mandatory. The other 4 (availability, processing integrity, confidentiality, privacy) are optional.

SOC 2 — The 5 Trust Services Criteria

Criterion	What It Covers	Required?
Security	Protects against unauthorized access	✓ Yes
Availability	System works when promised	Optional
Processing Integrity	Data is accurate and complete	Optional
Confidentiality	Private info stays private	Optional
Privacy	Personal data is handled properly	Optional

SOC 3 — Public Trust Signal

- ▶ **What it is:** A public version of SOC 2 — summarizes our report without sensitive details.
- ▶ **Why it matters:** We can post it on your website and share it freely in proposals.
- ▶ **Prerequisite:** We must have a SOC 2 Type 2 first — we can't issue SOC 3 without it.

Type 1 vs Type 2

	Type 1	Type 2
What It Tests	Design only	Design + operating effectiveness
When	Point-in-time	Over 6–12 months
Best For	First-time SOC	Gold standard — enterprise clients require this

ISO 27001 — Global Security Standard

- ▶ **What it is:** The international standard for building a security management system (ISMS).
- ▶ **What it requires:** Risk assessments, a Statement of Applicability (SoA), and 93 controls across 4 domains.
- ▶ **Why it matters:** Banking clients expect it. It's certifiable — an auditor issues a certificate if we pass.

ISO 27001 — Global Security Standard

Annex A — 93 Controls (4 Domains)

Domain	What It Covers	Examples
Organizational (37)	Governance, policies, vendor management	Incident response, vendor risk
People (8)	Employee security	Background checks, training
Physical (14)	Facilities and equipment	Badge access, CCTV
Technological (34)	Systems and data security	MFA, encryption, patching

ISO 27002 — How to Implement

- ▶ **What it is:** A guide on how to actually implement ISO 27001 controls — practical advice, not certifiable.
- ▶ **Key difference:** ISO 27001 tells us what to do. ISO 27002 tells us how to do it.
- ▶ **Use case:** Reference for security team when building controls.

Cyber Security Act 2024 — Malaysia's Cyber Law

- ▶ **What it is:** Malaysia's first dedicated cybersecurity law — enforced by NACSA.
- ▶ **Who it applies to:** NCII entities (National Critical Information Infrastructure) — banking, energy, healthcare, etc.
- ▶ **Key obligations:** Annual risk assessments, biennial audits, and incident reporting within 6 hours.
- ▶ **Penalty:** Up to RM500,000 fine + 10 years jail.
- ▶ **Silverlake relevance:** Banking = NCII — compliance is mandatory.

RMiT — Banking Tech Risk Rules

- ▶ **What it is:** Bank Negara's technology risk rulebook for financial institutions.
- ▶ **Who it applies to:** Banks, insurers, payment providers, and fintech.
- ▶ **Silverlake relevance:** Banks must comply — Silverlake's systems must support these requirements.

Guidelines on Technology Risk Management — Capital Market Tech Risk

- ▶ **What it is:** Securities Commission's technology risk guidelines.
- ▶ **Who it applies to:** Exchanges, clearing houses, CMSL holders, capital market entities.
- ▶ **Key areas:** Governance, technology risk management, AI governance (accountability, transparency, fairness), near-miss reporting.
- ▶ **Silverlake relevance:** If serving capital market clients, Silverlake must support these requirements.

PDPA — Malaysia Data Privacy

- ▶ **What it is:** Malaysia's law on processing personal data — covers how we collect, use, store, and protect personal data.
- ▶ **2024 amendments:** Mandatory breach notification — no longer optional.
Increased penalties — up to RM500,000.
- ▶ **Silverlake relevance:** Mandatory — Silverlake handles employee, customer, and client data.

General Data Protection Regulation — EU Data Privacy

- ▶ **What it is:** Europe's strict data privacy law — applies globally if we handle EU residents' data.
- ▶ **Key differences vs PDPA:** Stronger individual rights, 72-hour breach reporting, fines up to €20 million or 4% global turnover.
- ▶ **Silverlake relevance:** Only applies if Silverlake handles EU data.

Third-Party Risk Management

- ▶ **What it is:** The process of identifying, assessing, and monitoring risks from vendors and partners.
- ▶ **Why it matters:** A vendor's weak security becomes our weak security. 60% of breaches come from third parties.
- ▶ **Lifecycle:** Due diligence → contract security clauses → ongoing monitoring → offboarding.
- ▶ **Silverlake relevance:** Banking clients require it.

Business Continuity Management vs Disaster Recovery

	Business Continuity	Disaster Recovery
Focus	Keeping business running	Recovering IT systems
Scope	People, processes, facilities	Servers, databases, networks
Timeframe	Immediate to long-term	Post-incident
Objective	Stay operational	Restore systems

BCM = stay alive.

DR = get everything back to normal.

High Availability (HA)

- ▶ **What it is:** System design to prevent downtime — measured in "nines" of uptime.
- ▶ **Examples:** 99.9% = 43 minutes downtime/month. 99.99% = 4.3 minutes/month.
- ▶ **How to achieve it:** Redundancy (no single point of failure), load balancing, monitoring, regular testing.
- ▶ **Silverlake relevance:** Banking clients expect high availability — downtime directly impacts trust.

BCM, DR, and HA

Layer	Focus	Timeframe
High Availability	Prevent downtime	Milliseconds to minutes
Disaster Recovery	Recover from IT failure	Minutes to hours
Business Continuity	Keep business running	Hours to days

HA is about not going down.
DR is about getting back up.
BCM is about staying alive during the event.

Applicability Matrix

Framework	Applies?	Priority
SOC 1	✓ Likely	Medium
SOC 2	✓ Yes	High
SOC 3	✓ Optional	Low
ISO 27001	✓ Yes	High
ISO 27002	✓ Yes	Low
Cyber Security Act 2024	✓ Yes	Critical
RMiT (BNM)	✓ Yes	Critical
GTRM (SC)	⚠ Only if CM clients	Low
PDPA	✓ Yes	High
GDPR	⚠ Only if EU data	Low
TPRM	✓ Yes	High
BCM/DR	✓ Yes	High
High Availability	✓ Yes	High